

Affiliate Program for litemall

Feasibility audit, design decisions, and approved implementation plan

2026-07-16 · litemall microservices platform · status: **plan approved — implementation deferred to a future wave**

1. Executive summary

Question asked: Can the system register people as *affiliates* who promote our goods, earn commission, and log into the admin gateway (`litemall-gateway-admin` , :18080) with a restricted role — seeing only their own promoted products, earnings and withdrawals, never the full admin surface that `admin123 / mall123` see (AliExpress-Portals style)?

Verdict: Yes, it is doable — and cheaper than expected. The database schema already contains ~70% of a crmeb-style distribution vertical (referral columns, a complete commission ledger table, a wired withdrawal flow). What is missing is entirely code: nothing ever writes the referral columns, the commission ledger table has no Java mapper, no commission engine exists, and the admin gateway's role model is flat. The full plan below was reviewed and **approved on 2026-07-16**; implementation is deliberately deferred (saved to session memory as `affiliate-program-plan`).

Explicit non-goal: affiliates listing *their own* products. `litemall_goods` has no owner/seller column and there is no vendor table anywhere — a marketplace/multi-vendor model would be a new vertical, not part of this plan. Affiliates promote the shop's own catalog.

2. Feasibility audit — what exists today

2.1 Database schema (verified live against the dev DB)

Asset	State	Detail
<code>litemall_user</code> referral kit	SCHEMA ONLY	<code>spread_uid</code> , <code>spread_time</code> , <code>is_promoter</code> , <code>spread_count</code> , <code>pay_count</code> , <code>brokerage_price</code> (commission balance, separate from the <code>now_money</code> wallet), <code>path</code> (materialized referral tree, default <code>/0/</code>). All rows sit at defaults — no code ever writes them.
<code>litemall_user_brokerage_record</code>	SCHEMA ONLY	Created by <code>V7__add_distribution.sql</code> . Complete commission ledger: income/expense flag (<code>pm</code>), amount, balance-after, status (0 frozen / 1 valid / -1 invalid), freeze/unfreeze timestamps, link to order/extract. No mapper, domain class, or service exists — the table

		is unreachable from Java (the only table of its family with that gap).
litemall_user_extract (withdrawals)	WIRED	Bank fields, status, failure reason. Fully implemented: LitemallUserExtractService + order-service POST /srv/wallet/extract (alongside balance / bills / recharge).
Commission engine	MISSING	Order settlement never computes commission; brokerage_price is read into the wallet aggregate as brokerageBalance but never credited by anyone.
Referral capture at registration	MISSING	/auth/register (gateway-api) accepts no invite/referral parameter.
Multi-vendor / goods ownership	ABSENT	No seller/owner column on litemall_goods, no vendor table. Out of scope by decision.

2.2 Admin-gateway auth model (the key constraint)

The restricted-login requirement hinges on role tiers at the admin edge — and the audit showed **RBAC there is flatter than assumed**:

- AuthController.login issues the JWT claim roles=[ROLE_ADMIN] for **every** non-deleted litemall_admin ("minimal claim model"). The seeded roles (super administrator / mall manager / promotion manager in litemall_role, referenced by litemall_admin.role_ids) are **ignored by the token** — mall123 has identical edge access to admin123 today.
- AdminJwtAuthenticationManager grants ROLE_ADMIN to *any* valid token. **This must change to derive authorities from the JWT roles claim**, otherwise an affiliate token would silently become full admin — the single most security-critical line of the build.
- SecurityConfig gates /srv/private/admin/**, /srv/order/admin/** and /admin/** on the ADMIN authority; IdentityForwardingFilter already forwards X-User-Id + X-User-Roles downstream — the plumbing an affiliate role needs is in place.
- The admin SPA (menu.config.ts, admin-routes.tsx) has **no role gating at all** — one menu for everyone. Client-side gating will be UX only; the server-side matchers are the security boundary.

3. Locked design decisions

Decision	Choice (user-approved)	Rationale
Affiliate identity	Affiliates are <code>litemall_user</code> rows (<code>is_promoter=1</code>), not <code>litemall_admin</code> rows	All referral/commission columns live on <code>litemall_user</code> ; affiliates arrive via customer registration. No identity bridge needed.
Commission lifecycle	Frozen at pay → invalidated on approved aftersale → auto-unfrozen after a configurable freeze window	Matches the existing freeze/unfreeze ledger columns (<code>crmeb</code> model); refunds never claw back withdrawn money.
Enrollment	Admin-granted only (toggle on a new Promoters admin page)	Cleanest control, no abuse surface; self-serve signup is an easy later add.
Rate model	Flat global %, single level (direct referrer only)	One config key; the <code>path</code> column keeps multi-level cheap to add later.
Attribution	Invite code at registration (? <code>invite=CODE</code> → permanent <code>spread_uid</code> binding; all the referred user's future orders commission to the affiliate)	Uses existing schema only. Cookie/click attribution for existing users (true AliExpress model) is deferred to v2 — it needs a click table + storefront plumbing.

4. Approved implementation plan

Phase 1 — Brokerage engine (worktree `order` ; small gateway-api edit)

- Migration** `V<next>__brokerage_config.sql` — seed 4 `litemall_system` rows: `litemall_brokerage_enabled` (`false` = kill switch), `_rate`, `_freeze_days`, `_min_extract`. No new tables. (Config rows must pre-exist: the admin config endpoint silently no-ops unknown keys. Check `flyway_schema_history` for the next free number first.)
- litemall-db (hand-edit, never regenerate)** — new `LitemallUserBrokerageRecord` domain + slim mapper + XML (the `CjSourcingRequestMapper` pattern); atomic `creditBrokerage / debitBrokerage` guarded UPDATES on `LitemallUserMapper.xml`; verify the new columns appear in **every** result map (the known `now_money` silent-drop landmine). Reinstall `litemall-db` + restart all dependents.
- Registration referral** — `/auth/register` gains optional `inviteCode`: resolve referrer (promoter, live, not self), set `spread_uid/spread_time/path`, bump `spread_count`. Bad code = silently ignored (registration never fails on it). SPA `Register.tsx` pre-fills from ? `invite=`.
- Commission engine (order service)** — `BrokerageService` on `LitemallOrderPaidEvent` via `@TransactionalEventListener(AFTER_COMMIT)` + dedicated executor (payment is never

blocked — mirrors the Wave-4 auto-print listener): writes the FROZEN ledger row ($\text{price} = \text{goodsPrice} \times \text{rate}$). Aftersale-approval hook invalidates a matching frozen row. A scheduled sweep unfreezes matured rows and credits `brokerage_price`, one transaction per record.

5. **Withdrawals** — extract flow gains `source: wallet|brokerage`; brokerage extracts debit `brokerage_price`, enforce the minimum, and write an expense ledger row.

Phase 2 — Restricted affiliate portal (worktree `gateway-admin`; self-scoped endpoints in order service)

1. **Edge auth split** — new authority `ROLE_AFFILIATE`; `AdminJwtAuthenticationManager` derives authorities **from the roles claim** (critical fix); `POST /auth/affiliate/login|refresh|logout` authenticates against `litemall_user` (same BCrypt), requires `is_promoter=1`, issues `roles=[ROLE_AFFILIATE]` as `String[]` (the documented `JwtService.addClaim` List-serialization trap), refresh via `litemall_user_refresh_token` with `login_type='affiliate'`.
2. **Authorization** — `SecurityConfig` adds `/srv/private/affiliate/**` → `AFFILIATE`; every existing ADMIN matcher untouched; audit-log filter skips affiliate tokens; gateway route `/srv/private/affiliate/**` → order service, before the catch-all, in both route blocks.
3. **Affiliate API (always self-scoped via forwarded X-User-Id — no id parameters, no IDOR surface)** — `dashboard` (available / frozen / lifetime / this-month, team size, referred-orders count), `records` (paged ledger), `team` (referred users, masked), `links` (uid-derived invite code + share URLs per goods), `extract` + history.
4. **Admin surfaces** — Promoters page (`is_promoter` toggle + per-affiliate ledger), extract approval console (reject = refund + reason), `Sys/ConfigBrokerage` form.
5. **Affiliate SPA** — affiliate login tab; role-keyed router: `ROLE_AFFILIATE` sees only `/affiliate/**` (Dashboard, My Links + QR, Earnings, Team, Withdraw) and is redirected off `/admin/**`; `menu.config.ts` gains a role filter. Client gating is UX; the `SecurityConfig` matchers are the boundary.

Deferred to v2

- Cookie/click-based order attribution for existing users (`?aff=` + attribution window + click table).
- Multi-level commission (schema-ready via `path`), per-goods rates, promoter self-serve signup / auto-promotion.

5. Acceptance & verification (e2e through the gateways)

1. **Builds:** order + both gateways compile; both SPAs build; migration applies; `FlywayMigrationTest` green.
2. **Attribution:** register B via `/register?invite=<A's code>` → B's `spread_uid=A`, A's `spread_count +1`; bad/self code → clean registration with `spread_uid=0`.
3. **Commission:** B pays an order at rate 5% → exactly one FROZEN row with the correct amount; matured row → sweep credits A's balance, status→valid; approved aftersale before maturity → status→invalid, balance untouched.
4. **Portal & privilege separation:** A logs in at :18080 via the affiliate tab → dashboard sums match SQL; **A's token on any `/srv/private/admin/**` path → 403**; admin SPA routes redirect A away; `admin123 / mall123` logins and all existing admin surfaces regress clean; a non-promoter customer on affiliate login → 403.
5. **Withdrawal:** extract $\geq$ minimum debits `brokerage_price` + expense row + appears in the admin approval console; reject restores balance with a reason.
6. **Kill switch:** `litemall_brokerage_enabled=false` → paid orders write no ledger rows; the portal still opens showing zeros.

6. Status & next steps

- Plan **approved 2026-07-16**; implementation deferred at the user's request.
- Design + decisions persisted to session memory (`affiliate-program-plan`) and to `~/.claude/plans/jiggly-splashing-peach.md`.
- When given the go-ahead: convert Phase 1 → a `### Worktree: order` Wave-5 block and Phase 2 → a `### Worktree: gateway-admin` block in `CLAUDE.md` (the `CLAUDE.md` write was deliberately held back until then), then launch the two worktrees in dependency order (Phase 1 first — Phase 2's portal reads Phase-1 data, though the edge-auth split can start in parallel).

Sources: live dev-DB inspection (SHOW TABLES / DESCRIBE on `litemall_user`, `litemall_user_brokerage_record`, `litemall_user_extract`, `litemall_admin`, `litemall_role`); code audit of `litemall-gateway-admin` security/auth (SecurityConfig, AdminJwtAuthenticationManager, AuthController, IdentityForwardingFilter, menu.config.ts), `litemall-order` wallet controller/aggregates, `litemall-db` mappers and V7/V2/V3 migrations.